

UNIDAD FORMATIVA 6

L01. Principios legales y privacidad de datos en IA

Módulo 1. Modelos de Inteligencia Artificial

Índice

Ideas Clave	2
6.1 Privacidad de datos	3
6.1.1. Principios generales en materia de privacidad	3
6.1.1.1. Principios Generales de la Protección de Datos de ODCE	4
6.1.1.2. Principios Generales ISO/IEC 29100:2011	6
6.1.1.3. Protección de Datos en la UE – RGPD - GDPR	8
6.1.1.4. Protección de Datos en los EE. UU.	9
6.1.1.5. Comparativa UE-EE.UU. y consecuencias	10
6.1.2. Introducción al Reglamento General de Protección de Datos (RGPD)	12
6.1.2.1 Principales conceptos	20
6.1.2.3 Consideraciones importantes en los tratamientos de datos	23
6.1.2.4. Derechos de interesado	24
6.2 Protección frente a errores	26
6.2.1. Seguridad por Diseño	26
6.2.2. Privacidad por Diseño	27
A fondo	31

Ideas Clave

Para estudiar este tema lee las Ideas clave propuestas en el tema y revisa los contenidos adicionales para mejorar la comprensión y aumentar los conocimientos sobre las materias tratadas.

Este tema aborda los principios generales en materia de privacidad de datos y su protección desde la perspectiva internacional y europea, así como en el ámbito de la Inteligencia Artificial. Tomaremos como referencia la legislación Europea, y además nos introducimos brevemente en algún detalle de legislación internacional.

Es una realidad que la tecnología en general y la informática en particular están introduciéndose en la formación en profesiones en las que antes eran asignaturas totalmente externas como es el Derecho, la Medicina, Administración y Dirección de empresa y así un largo etcétera. Sin embargo, en los últimos años muchas de estas disciplinas incluyen preparación en productos específicos e incluso en sistemas analíticos.

Del mismo modo, en el campo formativo de la tecnología y sobre todo en el mundo de la Inteligencia Artificial debemos formarnos en el conocimiento de la legislación en materia de uso y protección de esos datos porque serán parte componente en el desarrollo de los requisitos y funcionalidades de la aplicación práctica de la IA.

Para coger soltura en la lectura de textos legales, aconsejamos consultar la información disponible en la web de la Agencia Española de Protección de Datos (AEPD) en cuanto a:

- Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo de 27 de abril de 2016 relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos), en adelante RGPD.

Por último nos acercaremos a principios de diseño que han surgido dentro de la disciplina de la ingeniería de desarrollo para contemplar los posibles fallos y errores en seguridad desde las etapas iniciales del proceso de desarrollo, configuración e implantación de sistemas y plataformas de inteligencia artificial.

6.1 Privacidad de datos

6.1.1. Principios generales en materia de privacidad

En este apartado revisaremos, de forma somera, los principios generales que deben observarse en materia de privacidad y protección de datos de carácter personal. El objetivo es crear el marco normativo que permita garantizar y proteger, en lo que concierne al tratamiento de datos personales, las libertades públicas y los derechos fundamentales de las personas físicas, y especialmente de su honor e intimidad personal y familiar.

La regulación en materia de protección de datos personales es muy dispar a nivel internacional, existiendo notables diferencias entre los marcos regulatorios, tanto desde el punto de vista del ámbito de aplicación como de los derechos reconocidos. En todo caso, podemos ver en este gráfico cómo existe una relación general entre todos los principios que tratan de regular.

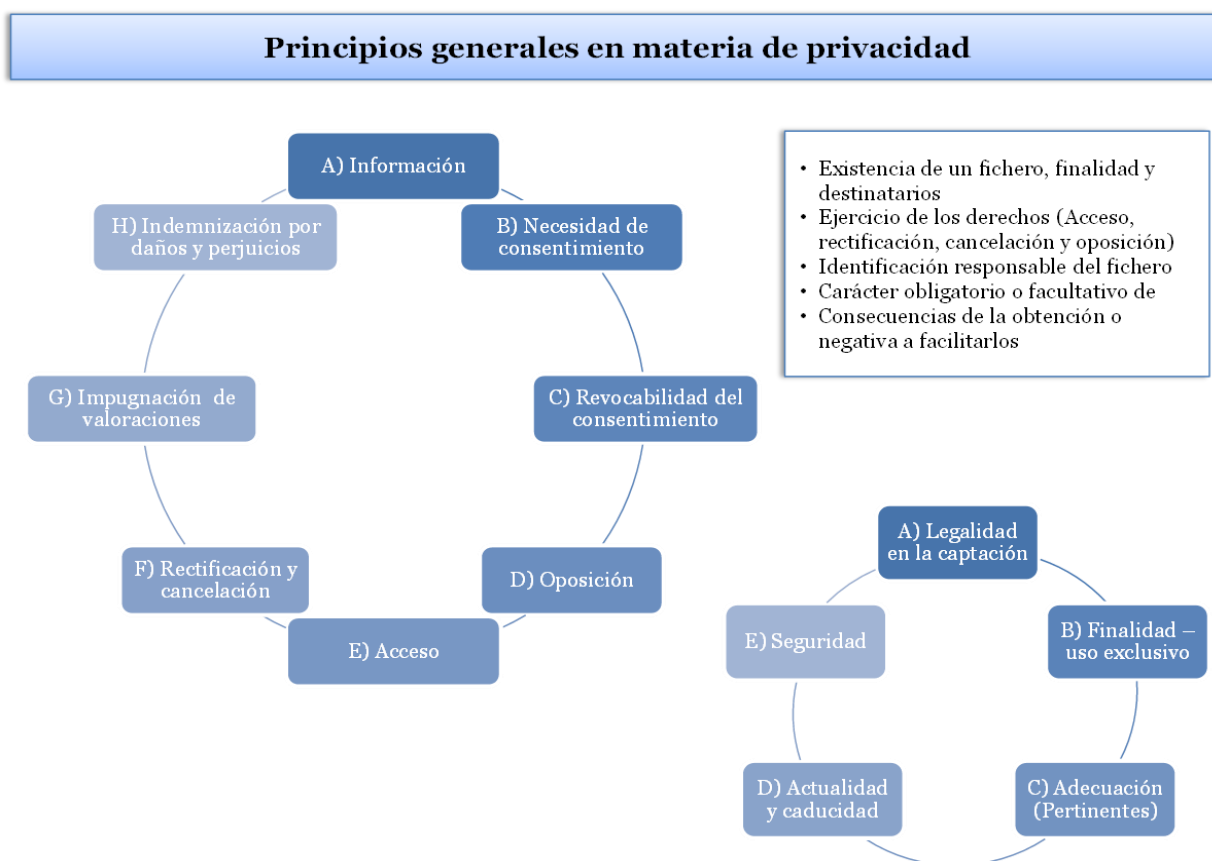


Ilustración 1. Principios generales en materia de privacidad.

Analizando la legislación de diferentes estados se identifican dos aproximaciones legislativas muy diferentes atendiendo a su tradición jurídica. Por un lado nos encontramos estados con un marco regulatorio general y completo, con leyes de tipo ómnibus que en algunos casos se complementa con regulaciones sectoriales. Por otro lado hay otros estados que cuentan con múltiples normas jurídicas sectoriales /territoriales, siendo en muchos casos complejo identificar todas y cada una de las normas aplicables.

Vamos a presentar una relación las definiciones que realizan tanto entidades normalizadoras y organismos internacionales a los conceptos (derechos, libertades y principios) como los principales países promotores internacionales de garantizar esta protección como son la UE y los EE.UU. de América.

Mientras los primeros formalizan marcos de referencia para garantizar la privacidad en los tratamientos de datos de carácter personal, y que no tienen un componente legal; los segundos sí que lo tienen. Así por ejemplo, de los primeros consideraremos por su interés:

- Principios Generales de la Protección de Datos de ODCE.
- ISO/IEC 29100:2011 Information technology -- Security techniques -- Privacy framework.

Para luego aproximarnos a las legislaciones de la UE y de los EE.UU. En el apartado 6.2. profundizaremos en **el GDPR** europea como referente mundial.

6.1.1.1. Principios Generales de la Protección de Datos de ODCE

OCDE el 23 de septiembre de 1980 formula "Las Directrices Relativas a la Protección de la Intimidad y de la Circulación Transfronteriza de Datos Personales", y que fueron posteriormente revisadas en 2013.

El documento nace con el objetivo de establecer un marco de referencia que armonice un ámbito en el que disparidades en las legislaciones de los estados miembros, dificulta el tráfico natural de los datos de carácter personal en el marco de las relaciones económicas. La visión de la protección de datos de carácter personal se desarrolla en torno a un conjunto de principios, denominados Principios Generales de la Protección de Datos de OCDE:

- 1. Principio de limitación en la recogida de datos.** Deben existir restricciones a la recopilación de datos personales y dichos datos deben obtenerse por medios lícitos y legales y, cuando corresponda, con el consentimiento de la persona tras ser informado.

2. **Principios de calidad de datos.** Los datos personales deben ser relevantes para los fines para los que serán utilizados, y, en la medida en que sean necesarios para esos fines, deben ser precisos, completos y mantenerse actualizados.
3. **Principio de propósito específico.** La finalidad para la que se recopilan datos personales debe especificarse a más tardar en el momento de la recopilación de datos y el uso posterior se limitará al cumplimiento de esos fines u otros que no sean incompatibles con las finalidades previstas y que se especifiquen en cada ocasión. de cambio de la finalidad del tratamiento de los datos.
4. **Principio de limitación en su utilización.** Los datos personales no deben divulgarse, ni ponerse a disposición o utilizarse de otro modo para fines distintos a los especificados, excepto:
 - (a) se dispone del consentimiento por parte de la persona; o
 - (b) por está permitido por la Ley.
5. **Principio de garantías de seguridad.** Los datos personales deberían estar protegidos por salvaguardias de seguridad razonables contra riesgos tales como la pérdida o el acceso no autorizado, destrucción, uso, modificación o divulgación de datos.
6. **Principio de apertura.** Debe existir una política general de apertura sobre desarrollos, prácticas y políticas con respecto a los datos personales. Debe haber medios disponibles para establecer la existencia y naturaleza de los datos personales, y el propósito principal de su uso, así como la identidad y residencia habitual del controlador de datos.
7. **Principio de participación individual.** Una persona debe tener el derecho de:
 - (a) obtener de un controlador de datos, o de otra forma, confirmación de si el controlador de datos tiene o no datos relacionados con él;
 - (b) que se le comuniquen a la persona, datos relacionados con él, dentro de un tiempo razonable; con un coste, en su caso, que no sea excesivo;
 - (c) de una manera razonable; y en una forma que sea fácilmente inteligible para él;

1. se informe a la persona de los motivos, en el caso de que sea rechazada una solicitud hecha bajo los subpárrafos (a) y (b), y para poder impugnar dicha denegación;

2. impugnar los datos relacionados con él y, si la impugnación tiene éxito, proceder a la eliminación de datos, su rectificación, o a ser completados o modificados

- 8. Principio de Responsabilidad.** Un controlador de datos debe ser responsable de cumplir con las medidas que dan efecto a los principios establecidos anteriormente.

Por último, hay que destacar que también la OCDE establece principios de transferencia internacional de datos.

6.1.1.2. Principios Generales ISO/IEC 29100:2011

La *International Organization for Standardization* (ISO) ha desarrollado la *ISO/IEC 29100:2011 Information technology - Security techniques - Privacy framework* y *ISO/IEC 29101:2013 Information technology - Security techniques - Privacy architecture framework*. Es un marco de referencia internacional de alto nivel para la protección de datos personales y que tiene una significativa penetración en el sudeste asiático, como vehículo adoptado por las compañías para mostrar internacionalmente su alineamiento con el marco y compromiso en el ámbito de la privacidad en entornos donde los marcos legislativos no son especialmente robustos y además, se toma como referencia en otros marcos ISO, como es el caso de la ISO/IEC 27001.

ISO/IEC 29100:2011, se desarrolla como parte del WG5 ISO/IEC/FIDIS/ITU-T de estándares de gestión de identidades, y el objetivo fundamental de ayudar a las organizaciones en el establecimiento de requerimientos de un marco operativo para salvaguardar la privacidad de individuos, lógicamente se orienta a sistemas que traten información de identificación personal (PII), teniendo dicha consideración en el marco del estándar la información que:

- Contiene un identificador asociado a una persona única, o la información está asociada a dicho identificador.
- Contiene un identificador que pueda estar relacionado a una persona única, o la información está asociada a dicho identificador.
- Contiene un identificador que pueda ser utilizado para establecer una comunicación con una persona concreta e identificada.
- La información contiene alguna referencia a datos de anteriormente indicados.

El marco se desarrolla en torno a **11 principios fundamentales**, que son:

1. **Consentimiento y elección:** el titular de los datos debe tener el derecho a decidir sobre el tratamiento de sus datos personales y debe estar informado de que derechos de asisten.
2. **Legitimidad de propósito y especificación:** la finalidad del tratamiento debe ser legal y debe haber sido notificada al afectado antes de obtener su consentimiento.
3. **Limitación en la recolección:** los datos a recolectar deben responder exclusivamente a requerimientos de necesidad del tratamiento.
4. **Minimización de datos:** que implica eliminar los datos cuando ya no son necesarios para el propósito del tratamiento y no exista requerimiento legal que lo impida e incorporar el principio de «necesidad de saben» en el acceso a los datos durante el tratamiento.
5. **Limitación de uso, retención y divulgación:** de acuerdo con los propósitos del tratamiento consentido por el titular.
6. **Exactitud y calidad:** garantizar que los datos tratados son completos, actualizados y exactos.
7. **Apertura, transparencia y notificación:** informar a los interesados de la política del tratamiento de datos y de cualquier cambio al respecto.
8. **Participación individual y acceso:** facilitar al interesado el acceso a sus datos y el ejercicio de sus derechos.
9. **Rendición de cuentas:** la asignación de la responsabilidad de la política de tratamiento de datos personales de la organización, con responsabilidades de informar al titular de los datos de brechas de seguridad, gestionar cesiones o comunicaciones de datos o encargados de tratamiento y fomentar la concienciación y formación del personal con acceso a datos.
10. **Seguridad de la información:** incorpora los controles operativos necesarios para garantizar la disponibilidad, integridad y confidencialidad de la información.
11. **Cumplimiento de la privacidad:** verificar la eficacia de los controles de seguridad mediante auditorias y de las políticas de privacidad.

6.1.1.3. Protección de Datos en la UE – RGPD - GDPR

El Reglamento General de Protección de Datos (Reglamento 2016/679) RGPD – *General Data Protection Regulation* (GDPR es su acrónimo en inglés y es ampliamente utilizada a nivel mundial) es un reglamento por el que el Parlamento Europeo, el Consejo de la Unión Europea y la Comisión Europea tienen la intención de reforzar y unificar la protección de datos para todos los individuos dentro de la Unión Europea (UE).

También se ocupa de la exportación de datos personales fuera de la UE. El objetivo principal del **RGPD** es dar control a los ciudadanos y residentes sobre sus datos personales y simplificar el entorno regulador de los negocios internacionales unificando la regulación dentro de la UE.

El GDPR sustituyó a la Directiva de protección de datos (oficialmente Directiva 95/46 / CE) de 1995. El Reglamento fue adoptado el 27 de abril de 2016. Se convirtió en ejecutivo a partir del 25 de mayo de 2018 tras una transición de 2 años y, a diferencia de una directiva, no obliga a los gobiernos nacionales a aprobar ninguna legislación habilitante, por lo que es directamente vinculante y aplicable (trasposición de norma).

Proporciona una armonización de los reglamentos de protección de datos en toda la UE, facilitando así que las empresas no europeas cumplan estas normas; sin embargo, esto se produce a costa de un estricto régimen de cumplimiento de la protección de datos con severas sanciones de hasta el 4% del volumen de negocios mundial.

Buscaba 2 objetivos principales:

- Por un lado, la UE **quiere dar a las personas más control sobre cómo se utilizan sus datos personales**, teniendo en cuenta que muchas empresas como Facebook y Google intercambian el acceso a los datos de las personas para el uso de sus servicios (muchas leyes anteriores venían de épocas anteriores a Internet y la nube).
- Por otro lado, la UE quiere dar a las empresas **un entorno jurídico más simple y claro para operar**, haciendo que la ley de protección de datos sea idéntica en todo el mercado único.

Los “**controladores**” y los “**procesadores**” de datos deben atenerse al GDPR. Un controlador de datos indica cómo y por qué se procesan los datos personales, mientras que un procesador es la parte que realiza el procesamiento real de los datos. Por lo tanto, el controlador podría ser cualquier organización, desde una

empresa con fines de lucro hasta una organización benéfica o un gobierno. Un procesador podría ser una empresa de TI que realice el procesamiento de datos real.

Incluso si los controladores y procesadores están fuera de la UE, el GDPR seguirá aplicándose a ellos siempre y cuando se trate de datos pertenecientes a residentes de la UE.

Más adelante, trataremos varios aspectos importantes sobre este reglamento profundizando en su comprensión. Además en siguientes capítulos y lecciones veremos cómo utilizar algunas técnicas para llevarlo a la práctica.

6.1.1.4. Protección de Datos en los EE. UU.

La *Privacy Act*, que sería posteriormente modificada entre otros por las enmiendas surgidas de las leyes de Libertad de Información (*Freedom of information Act*) es de aplicación a las bases de datos del Gobierno Federal con ciertas limitaciones, como son los archivos de los servicios de inteligencia, inmigraciones, lucha con el narcotráfico...) y reconoce el derecho de acceso a la información personal.

En este punto podemos encontrar cierta similitud con los principios que rigen la protección de datos en la UE, pero es una Ley que afecta solo al Gobierno Federal y es que el sistema jurídico anglosajón se desarrolla entorno a leyes sectoriales en lugar del establecimiento de un marco general regulador, tipo ómnibus, como es el caso de la UE y de España.

Así, existen un conglomerado de normas a nivel federal y estatal, al que se suman cientos de desarrollos normativos específicos de los estados miembro (como, por ejemplo, California que dispone de más de 25 normas sobre privacidad y seguridad de datos). En EE.UU. no existe un organismo de control general en materia de protección de datos, como sí sucede en la UE, pero sí dispone de instituciones o autoridades de vigilancia y control sectoriales.

En general regula:

- tanto la información previa a la recolección de los datos (especialmente los de carácter sensible) y la utilización para las finalidades permitidas.
- requerimientos de seguridad, garantizando la confidencialidad e incluso en ciertos estados, la obligación de comunicar brechas de seguridad que afecten a datos personales.

6.1.1.5. Comparativa UE-EE.UU. y consecuencias

Es interesante que conozcamos qué relación mantienen ambas legislaciones porque tanto en el uso de sistemas de software, con los datos que manejan, como en el uso de repositorios (BBDD, datalakes, DWH) en las diferentes 'nubes' disponibles como en el intercambio de datos entre aplicaciones y empresas estamos sujetos a ciertas fronteras que determinarán requisitos importantes en la recopilación, uso y envío de todos estos datos.

Aunque existen amplios puntos de convergencia entre las normativas de EE. UU y la UE sí que han tenido recorridos distintos. Las primeras ideas sobre protección de datos a ambos lados del Atlántico nacen en la década de los 70, y uno de los fundamentos de los principios recogidos en el Convenio de Protección de Datos del Consejo de Europa (1981) tenían como inspiración los Principios de información justa (Report of the Secretary's Advisory Committee on Automated Personal Data Systems: Records, Computers and the Rights of Citizens , 1973), principios que también inspiraron las directrices de Privacidad de la OCDE (1980).

Sin embargo, estos principios evolucionaron de forma diferente apostando en EE. UU por la autorregulación, mientras que en UE llegó a la consideración de derecho fundamental, vinculante en el Tratado de Lisboa de 2009.

Por ello el modo y alcance en el que se reconocen los derechos entorno a la protección de datos presentan notables divergencias:

- En la propia concepción del derecho que ya se manifiestan [entre la Cuarta enmienda de la Constitución de EE. UU. con un alcance más limitado que el derecho a la vida privada que reconoce el artículo 7 de la Carta de la UE, donde «toda persona tiene derecho al respeto de su vida privada y familiar, de su domicilio y de sus comunicaciones».](#)
- En la sustancial diferencia en la concepción de "datos personales". En la UE como hemos visto, abarca toda información que identifica o hace identificable a una persona. Una definición mucho más amplia que la extendida en EE. UU., que se centra más en el dato que identifica y **no en el dato que hace posible la identificación de las personas**. También es posible encontrar alguna excepción a esto. [Por ejemplo, en la nueva regulación COPPA \(Children's online privacy protection rule\) del FTC \(Federal trade commission\) se reconoce como dato personal el "identificador persistente que pueda ser utilizado para reconocer a un usuario en el tiempo a lo largo de diferentes web sites o servicios online".](#)

Esta concepción hace que la Ley de EE. UU. **se centre en reparar el daño al «consumidor» y la búsqueda de un adecuado equilibrio entre privacidad y las necesidades relacionadas con las transacciones comerciales** que fundamenta la no existencia de restricciones en EE. UU. en relación con la exportación de datos (excepto para ciertas informaciones gubernamentales), con un impacto significativo en los flujos de datos internacionales.

Un escenario en el que las organizaciones y las empresas de la UE se ven sometidas a muchas más restricciones que las de EE. UU.

Las implicaciones de estas divergencias y su impacto están detrás del debate dentro de la comunidad en busca de una mitigación de las barreras existentes a través de una aproximación en el concepto de Dato Personal en EE. UU. Por ejemplo, de **PII 2.0. (Personal identification information)** que incorporaría al concepto de dato personal en EE. UU. de datos de personas identificables y la evaluación continua del riesgo de identificación.

Y también en el desarrollo del concepto de puerto seguro (*Safe Harbour*) como vía para facilitar la exportación de datos entre la UE y los EE. UU. Desde su origen es un sistema considerado de débil garantía pues parte de la auto-certificación de las propias entidades de EE. UU. sobre el cumplimiento de los requerimientos establecidos en el *Safe Harbour* y sus mecanismos de control.

Ambas partes, EE. UU y UE son conscientes de la importancia de suavizar las barreras a flujo de datos personales orientando iniciativas con el objeto de restablecer la confianza entre las partes. Y actualmente está vigente un nuevo marco que trata de corregir las debilidades del anterior: **Privacy Shield**.

El **Privacy shield**, fue la respuesta por parte de la Comisión Europea y el *Department of Commerce* de EEUU a la sentencia del Tribunal de Justicia Europeo, octubre de 2015, que invalidaba el marco de transferencias internacionales entre UE- EEUU vigente hasta entonces, el *Safe Harbor*, pues el tribunal no reconocía que ofreciera un espacio garantista y equivalente al de la UE .y a una necesidad evidente: la de facilitar el flujo de datos, en el ámbito de las relaciones comerciales entre los dos lados del Atlántico, que cuentan con marcos de protección de datos diferentes en lo que hace referencia a los principios y derechos, con una legislación de EEUU menos proteccionista, en aspectos como por ejemplo, el seguimiento de usuarios en Internet.

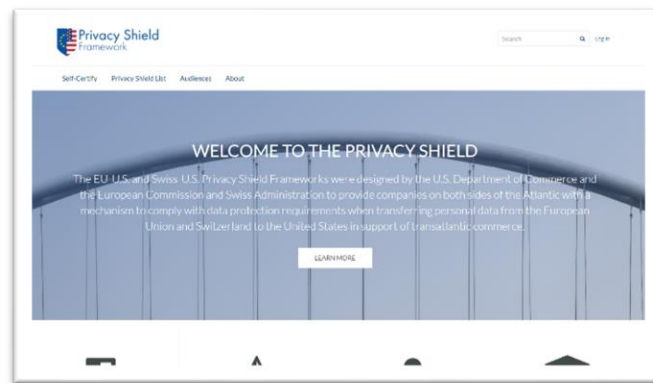


Ilustración 2. Portal Privacy Shield

6.1.2. Introducción al Reglamento General de Protección de Datos (RGPD)

Los proyectos de inteligencia artificial **están basados en datos**. Necesitamos datos para entrenar y para validar los modelos. También necesitamos almacenar y analizar los datos que genera la interacción con el modelo, solo así seremos capaces de determinar si la puesta en práctica de la solución cumple con los objetivos previstos. La evaluación constante de los modelos es lo que permite su mejora y evolución.

Por tanto, los proyectos de inteligencia artificial se ven claramente influenciados por la legislación vigente en materia de protección de datos.

Como hemos comentado anteriormente el RGPD, traslación del reglamento europeo **GDPR (General Data Protection Regulation)**, es un marco legal que regula la protección de los datos de carácter personal, a nivel europeo. Esto implica la protección de cualquier ciudadano o empresa de la UE frente al uso de los datos que tengan ese carácter.

Bajo el paraguas de la Unión Europea surge el Reglamento General de Protección de Datos (RGPD), con la aspiración de unificar los regímenes de todos los Estados miembros sobre la materia. Aunque entró en vigor el día 25 de mayo de 2016, su cumplimiento solo será obligatorio transcurridos dos años desde esta fecha.

Aunque diseñada en el año 2016, el RGPD de la Unión Europea pasó a ser de obligado cumplimiento en el año 2018. La aplicación de esta normativa supone un gran reto para muchas compañías en las que el dato y la analítica sobre el mismo constituye un eje esencial de su actividad. El incumplimiento de la normativa implica cuantiosas multas para los infractores.

El RGPD **exige medidas adicionales que garanticen la transparencia en el tratamiento de datos personales**. Se pretende así empoderar al ciudadano para que tome las decisiones más adecuadas. Las organizaciones deben informar al usuario sobre el tipo de perfilado o modelización que realizan en base a su dato personal facilitándole la denegación del permiso para realizar dicho tratamiento si así es solicitado.

Especialmente en el entorno financiero y asegurador, una de las medidas que más impacto causa es el **derecho a explicación**. Esta medida obliga, por ejemplo, a las entidades financieras a explicar las razones por las que un crédito ha sido denegado. De esta forma, el usuario puede actuar en consecuencia buscando alternativas para obtener una mejor clasificación en el futuro.

Además, los algoritmos implementados deben asegurar que se garantiza la no discriminación a la hora de tomar decisiones basadas en datos. No podrán tomarse decisiones basadas en criterios como la raza, la edad, el sexo, la religión, etc.

La Unión Europea ha habilitado el portal <https://gdpr.eu/> donde se desglosa todo tipo de información sobre esta regulación y que nos disponen en [pdf](#).



Ilustración 3. Portal de la UE con toda la información del GDPR
Fuente: <https://www.gdpr.eu>

GDPR.eu es un recurso muy útil de la UE que permite encontrar rápidamente los 99 artículos y 173 considerandos del Reglamento, así como guías útiles y listas de verificación que lo guiarán a través de cómo el Reglamento puede aplicarse en su caso.

En España, la Agencia Española de Protección de Datos (AEPD), como autoridad de control independiente, tiene encargada la misión de velar por el cumplimiento de la normativa de protección de la información personal.

La agencia es un ente de derecho público, con personalidad jurídica propia y plena capacidad pública y privada, que actúa con plena independencia de las Administraciones públicas en el ejercicio de sus funciones. Se relaciona con el Gobierno a través del Ministerio de Justicia. La Ley Orgánica de Protección de Datos de Carácter Personal (LOPD) 15/1999, de 13 de diciembre, regula gran parte de las directrices que se deben tener en cuenta a la hora de manipular información personal.



Ilustración 4. Página web de la AEPD

Fuente: <https://www.agpd.es/portalwebAGPD/index-ides-idphp.php>

A continuación, se desglosarán **algunas de las características más destacadas de las legislaciones y reglamentos en este campo de la privacidad y la protección de datos**, así como sus implicaciones para la tipología de los proyectos que nos ocupa. Más adelante relacionaremos en detalle estos conceptos con los artículos específicos del reglamento.

Protección de datos de carácter personal

Se considera un dato de carácter personal **cualquier información concerniente a personas físicas identificadas o identificables**. Por tanto, la legislación no solo contempla como datos de carácter personal aquellos casos en los que es posible identificar unívocamente al individuo en base a un atributo exclusivo como el documento nacional de identidad. También contempla la posibilidad de que dicha identificación pueda producirse en el futuro vía cruce de datos de distintas tipologías.

Por ejemplo, supongamos que tenemos almacenada en un fichero o base de datos información sobre los clientes de una determinada compañía. Supongamos ahora que contamos con campos poco relevantes y genéricos. En esta situación, la compañía decide añadir la edad de cada usuario a la información existente. Si los datos anteriores realmente son irrelevantes (siempre referido a cuestiones de identificación personal), la edad por sí sola no podría servir para identificar a un individuo, puesto que, ¿cuántas personas hay de 20 años?, ¿y de 35? Las opciones son muy diversas. En estas condiciones, la compañía decide incorporar a la base de datos el género. Ahora las opciones se reducen, evidentemente, hay más personas que tienen 35 años a personas que tienen 35 años y son mujeres (por

ejemplo). No obstante, parece poco creíble pensar que solo existe una única persona que tenga 35 años y sea mujer. Animados por lo útil que es insertar este tipo de atributos en el estudio, el responsable del proyecto decide ahora incorporar el código postal del usuario. En esta situación, y si la compañía dispone de especialistas en seguridad y normativa de protección de datos, se levantará una señal de alarma. Con la edad, género y código postal sí que existe una mínima posibilidad de que se pueda identificar de forma unívoca a una persona (especialmente en grupos de edades menos frecuente). En diversos entornos de la materia, a la combinación de los atributos edad, género y código postal se la conoce con el nombre de triada.

Antes de continuar, queremos dejar patente que no se prohíbe el almacenamiento de información personal. Si así fuese, ninguna empresa o institución pública podría funcionar. **La misión de la ley es establecer distintos niveles obligatorios de seguridad y control** en función de la tipología de la información. Incluso dentro de la información que puede ser considerada como información personal existen distintos niveles de criticidad. No es lo mismo almacenar edad, género y código postal, que almacenar el número de la cuenta bancaria o, más crítico todavía, el número completo de la tarjeta de crédito con su fecha de caducidad y código de seguridad.

Las distintas iniciativas regulatorias que van surgiendo se encaminan a posibilitar a los usuarios finales o clientes un mayor control sobre los datos que ceden a las compañías y el uso que estas hacen de estos datos. En su artículo 4, la LOPD dice:

- «1. Los datos de carácter personal solo se podrán recoger para su tratamiento, así como someterlos a dicho tratamiento, cuando sean adecuados, pertinentes y no excesivos en relación con el ámbito y las finalidades determinadas, explícitas y legítimas para las que se hayan obtenido.»
- «2. Los datos de carácter personal objeto de tratamiento no podrán usarse para finalidades incompatibles con aquellas para las que los datos hubieran sido recogidos. No se considerará incompatible el tratamiento posterior de estos con fines históricos, estadísticos o científicos.»

Es por tanto preciso que **el propietario de los datos autorice el almacenamiento y tratamiento de su información personal**. Así mismo, los responsables del repositorio de datos deben garantizar a los usuarios los métodos adecuados para la rectificación, modificación, acceso y cancelación de la información suministrada.

Confianza

Dentro de ciertos sectores sociales existe una preocupación relevante por el uso que determinadas compañías están haciendo con sus datos, y quizá esta preocupación esté justificada si nos basamos en ciertos titulares periodísticos que se han publicado en los últimos años. En este tipo de cuestiones entraremos más en detalle en el próximo apartado. Ahora intentaremos explicar cómo se puede establecer una relación de confianza entre el usuario y la organización para que éste ceda sus datos.

Supongamos que un paciente estándar de 50 años está en la revisión anual con su médico. El hospital está interesado en crear un banco de datos y compartirlos con personal externo. Dado que es obligatorio otorgar permiso explícito para ceder datos de carácter personal, el facultativo nos pide delante un formulario donde simplemente se indica el texto: «autorizo la cesión de mis datos ...».

Sin disponer de más información, ¿qué haría el lector? Cambiemos la situación yendo a un caso algo más extremo.

Supongamos que ese mismo paciente ha sido diagnosticado recientemente de una enfermedad que tiene una incidencia muy baja, pero, desgraciadamente, sus efectos en el enfermo son importantes. Textualmente, lo que nos comenta ahora el médico es:

«Nos gustaría que nos cediese su datos personales y clínicos para incorporarlos a nuestro banco de datos. Lo que pretendemos con este proyecto es compartir información con especialistas de todo el país e investigadores muy destacados en el área. Dado que su enfermedad es extremadamente rara, consideramos que sería muy útil compartir sus datos con la comunidad científica. Seguro que así podremos recibir recomendaciones que nos ayudaría a personalizar el tratamiento a sus características. Además, no compartiremos sus datos personales más íntimos, toda la información estará anonimizada. Ante cualquier cuestión, seremos nosotros quienes nos comunicaremos con usted como venimos haciendo hasta ahora».

¿Qué haría el lector en esta hipotética situación?

Es probable que las respuestas ante ambos casos de uso sean muy distintas. Y sería normal, puesto que se trata de dos casos muy diferentes. En la primera situación, el paciente no aprecia el retorno de valor que le produce la cesión de sus datos. Además, al recibir poca información sobre el proyecto es difícil generar una relación de confianza. En el segundo caso, el beneficio que el

paciente percibe como consecuencia de la cesión de datos es evidente y relevante. La comunidad podría aportar un tratamiento que retarde la enfermedad o incluso la cure. Pero para que esto sea una realidad es preciso que especialistas compartan información sobre qué tratamientos han funcionado, cuáles no, cuáles han sido los efectos secundarios, qué peculiaridades tenían los pacientes... Además, el facultativo ha trabajado la confianza al solicitar la cesión de los datos, ha explicado la utilidad de la cesión de los datos y ha establecido unas garantías que invitan al paciente a estar tranquilo sobre quién podrá contactarle. ¿Cuántas veces hemos recibido llamadas publicitarias ofreciendo productos sin ningún tipo de interés para nosotros y sin saber cómo habían accedido a nuestros datos?

Lo que se ha pretendido explicar en los párrafos anteriores se puede resumir en los siguientes puntos:

- Los algoritmos de inteligencia artificial (por ejemplo, los algoritmos de aprendizaje automático) emplean datos como materia prima.
- Muchas veces estos datos incluyen información personal.
- Para manipular información personal (aunque esté anonimizada) el usuario debe haber emitido su autorización.
- Para que el usuario ceda sus datos personales es preciso trabajar un entorno de confianza. Este entorno de confianza se basa en los siguientes puntos:
 - El usuario tiene claro a quién (a nivel de institución) y para qué va a acceder los datos.
 - El usuario tiene claro qué se va a hacer con sus datos.
 - El usuario percibe un retorno de valor evidente que le invita a permitir la cesión de datos.
 - El usuario es informado de que sus datos van a ser tratados de forma adecuada y segura.

Establecer mecanismos que cultiven e implementen esta relación de confianza entre el usuario o cliente y la empresa o la institución es uno de los grandes retos a los que se enfrenta la industria hoy en día.

Anonimización de datos personales

El tratamiento, análisis y explotación de grandes volúmenes de datos puede producir infinitud de beneficios a la sociedad, pero es preciso compatibilizar dicho almacenamiento y manipulación con el respeto a la protección de datos personales.

El mecanismo principal que permite alinear la generación de beneficios tangibles con el respeto a la privacidad es la **anonimización de la información**. Según la RAE, anonimizar es «expresar un dato relativo a entidades o personas, eliminando la referencia a su identidad». Por otro lado, y según la AEPD, «un proceso de anonimización es aquel que elimina o reduce al mínimo los riesgos de identificación de los datos anonimizados manteniendo la veracidad de los resultados tras el tratamiento de los mismos».

Para garantizar su efectividad, **este proceso de anonimización debe ser irreversible**. Es decir, no debe existir posibilidad de recuperar el dato adicional empleando solo los datos anonimizados. Es necesario precisar que, debido a los avances tecnológicos y algorítmicos, no es posible garantizar de forma absoluta y completa la anonimización de la información. El objetivo realizable es proporcionar las mayores garantías posibles de cara a asegurar el respeto a la privacidad de las personas.

Según la AEPD, el proceso de anonimización debe atender a los siguientes principios:

- ▶ **Principio proactivo.** La privacidad se debe garantizar de forma proactiva y no de forma reactiva y una vez que se haya producido alguna fuga de información.
- ▶ **Principio de veracidad por defecto.** Se debe considerar la granularidad o grado de detalle final que deben tener los datos anonimizados. Esto lleva a que, en ocasiones, se exija la eliminación de ciertos datos para garantizar la anonimización del conjunto.
- ▶ **Principio de privacidad objetiva.** Siempre existirá un error residual de riesgo de re-identificación que deberá ser aceptable en función de la información anonimizada, conocido por el usuario y asumido por el responsable del fichero.
- ▶ **Principio de plena funcionalidad.** El proceso de anonimización debe garantizar la utilidad de los datos anonimizados en base a los objetivos inicialmente establecidos.
- ▶ **Principio de privacidad en el ciclo de vida de la información.** El respeto a la privacidad de los usuarios debe garantizarse durante todo el proceso de anonimización. Por ejemplo, realizando el proceso de anonimización en los sistemas preparados y autorizados a almacenar la información sin anonimizar.
- ▶ **Principio de información y formación.** Todo el personal con acceso a datos anonimizados o no deben estar correctamente formados e informados acerca de sus obligaciones.

Técnicamente hablando, existen varios procedimientos para asegurar la anonimización de la información. Algunos de los más destacados son:

- ▶ **Desnaturalizar:** consistente en transformar la naturaleza del dato. Por ejemplo, en lugar de representar la edad (edad = 42), podemos indicar el rango de edad al que pertenece en base a alguna división previamente establecida (edad = 5 donde 5 hace referencia al intervalo [40, 50]).
- ▶ **Cifrar:** consiste en hacer ilegible un mensaje concreto en base a la aplicación de un algoritmo que precisa de un conjunto de claves. En este caso, el descifrado de la información es posible siempre que se disponga del algoritmo de las claves necesarias.
- ▶ **“Tokenizar”:** se reemplaza el valor a anonimizar por un valor distinto (*token*) que no suele respetar la naturaleza del dato. Por ejemplo, se “tokeniza” el DNI 04345566D cambiándolo por el valor YID884S3VVQW4ZZY1. Se puede observar cómo no se respeta el formato estándar de un DNI. Para que el proceso mantenga la coherencia, al mismo valor le debe siempre corresponder el mismo *token*. La reversibilidad es posible siempre que se disponga del *token* correspondiente a cada valor.
- ▶ **Funciones hash:** es un método parecido a la “tokenización”. En este caso se aplica una función matemática al valor a anonimizar. Dicho valor reemplaza al valor original. En este caso, y por la propia naturaleza del proceso, se garantiza la irreversibilidad del proceso. No obstante, esta técnica podría, ocasionalmente, generar el mismo valor *hash* para distintos valores de entrada.
- ▶ **Disociar:** eliminar parte de la información para evitar la identificación personal. Por ejemplo, pongamos que disponemos de la siguiente información sobre un paciente: fecha de la consulta, hora de la consulta, código postal, edad, sexo y síntomas. Con esa información encima de la mesa existiría un riesgo de identificar al paciente, ya que solo la fecha y hora de la consulta proporcionan bastante información. La disociación consistiría en eliminar ciertos campos quedándonos solo (por ejemplo), con código postal, sexo y síntomas. De esta forma se reduce el riesgo de identificación.

6.1.2.1 Principales conceptos

El lector técnico está poco acostumbrado al acceso a documentación y recursos legales, y sin embargo, cada vez se hace más necesaria la comprensión de los requisitos legales a tener en cuenta en la configuración y desarrollo de software. A continuación resaltamos conceptos importantes a

tener en cuenta a la hora de trabajar con datos y que han sido definidos de forma expresa en la RGPD:

Cuadro recopilatorio de algunos conceptos y definiciones útiles en el RGPD GDPR	
Concepto	Definición y aclaraciones de interés
Datos personales (art.4, 4.1)	• «[...] toda información sobre una persona física identificada o identificable (el interesado)». • Se considerará persona física identificable «toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona;» • Uno de los aspectos más controvertidos por su carácter interpretativo se deriva del término 'identificable', es decir información que facilita de manera indirecta identificar a una persona. Este sería el caso de por ejemplo la dirección IP, el número de teléfono fijo, la cadena de ADN, la huella dactilar, datos biométricos...
Tratamiento (art.4.2)	• «[...] cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales, ya sea por procedimientos automatizados o no, como la recogida, registro, organización, estructuración, conservación, adaptación o modificación, extracción, consulta, utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo o interconexión, limitación, supresión o destrucción» • No se hace distinción en referencia al sistema de tratamiento ni si este es de limitado alcance. La definición recoge ampliamente cualquier tipo de actuación u operación sobre datos que sea posible realizar.
Elaboración de perfiles (art.4.4)	• «[...] forma de tratamiento automatizado de datos personales consistente en utilizar datos personales para evaluar determinados aspectos personales de una persona física, en particular para analizar o predecir aspectos relativos al rendimiento profesional, situación económica, salud, preferencias personales, intereses, fiabilidad, comportamiento, ubicación o movimientos de dicha persona física.»
Pseudoanonimización (art.4.5)	• «... el tratamiento de datos personales de manera tal que ya no puedan atribuirse a un interesado sin utilizar información adicional, siempre que dicha información adicional figure por separado y esté sujeta a medidas técnicas y organizativas destinadas a garantizar que los datos personales no se atribuyan a una persona física identificada o identificable»
Fichero (art.4.6)	• «... todo conjunto estructurado de datos personales, accesibles con arreglo a criterios determinados, ya sea centralizado, descentralizado o repartido de forma funcional o geográfica»

Responsable del tratamiento o responsable (art.4.7)	« .. la persona física o jurídica, autoridad, servicio u otro organismo que, solo o junto con otros, determine los fines y medios del tratamiento»
Encargado del tratamiento o responsable (art.4.8)	« .. la persona física o jurídica, autoridad, servicio u otro organismo que trate los datos personales por cuenta del responsable del tratamiento»
Destinatario del tratamiento o responsable (art.4.9)	« .. la persona física o jurídica, autoridad, servicio u otro organismo al que se comuniquen datos personales, se trate o no de un tercero. No obstante, no se considerarán destinatarios las autoridades que 4.5.2016 L 119/33 Diario Oficial de la Unión Europea ES puedan recibir datos personales en el marco de una investigación concreta de conformidad con el Derecho de la Unión o de los Estados miembros; el tratamiento de tales datos por dichas autoridades será conforme con las normas en materia de protección de datos aplicables a los fines del tratamiento»
Tercero (art.4.10)	« .. persona física o jurídica, autoridad, servicio u organismo distinto del interesado, del responsable del tratamiento, del encargado del tratamiento y de las personas autorizadas para tratar los datos personales bajo la autoridad directa del responsable o del encargado»
Consentimiento del interesado (art.4.11)	« .. toda manifestación de voluntad libre, específica, informada e inequívoca por la que el interesado acepta, ya sea mediante una declaración o una clara acción afirmativa, el tratamiento de datos personales que le conciernen» - El consentimiento, viene a ser reforzado en el RGPD, de manera que el consentimiento presunto no es aceptado.
Violación de la seguridad de los datos personales (art.4.12)	« .. toda violación de la seguridad que ocasione la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos» - Hay ámbitos en los que es común la utilización del término brecha de seguridad a la hora de hablar de una violación.
Datos genéticos (art.4.13)	« .. datos personales relativos a las características genéticas heredadas o adquiridas de una persona física que proporcionen una información única sobre la fisiología o la salud de esa persona, obtenidos en particular del análisis de una muestra biológica de tal persona»
Datos biométricos (art.4.14)	« .. datos personales obtenidos a partir de un tratamiento técnico específico, relativos a las características físicas, fisiológicas o conductuales de una persona física que permitan o confirmen la identificación única de dicha persona, como imágenes faciales o datos dactiloscópicos» - Los datos biométricos tienen un uso más generalizado como métodos de autenticación de las personas.

	Referente este tema resaltar que el RGPD, permite a los estados miembros legislar sobre las condiciones adicionales o limitaciones del tratamiento de datos biométricos, genéticos o relativos a la salud (véase Art. 9.4).
Datos relativos a la salud (art.4.15)	« .. datos personales relativos a la salud física o mental de una persona física, incluida la prestación de servicios de atención sanitaria, que revelen información sobre su estado de salud» - Los datos de salud disponen de un marco de amparo garantista específico por las características y el impacto que dichos datos tienen en los ciudadanos, de ahí que exista una definición específica al respecto.
Objeción pertinente y motivada (art.4.24)	« .. la objeción a una propuesta de decisión sobre la existencia o no de infracción del presente Reglamento, o sobre la conformidad con el presente Reglamento de acciones previstas en relación con el responsable o el encargado del tratamiento, que demuestre claramente la importancia de los riesgos que entraña el proyecto de decisión para los derechos y libertades fundamentales de los interesados y, en su caso, para la libre circulación de datos personales dentro de la Unión»

6.1.2.3 Consideraciones importantes en los tratamientos de datos

Otro detalle importante a trabajar es el concepto de **tratamiento** que hemos visto en el artículo 4.2 y que se define como "cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales..". Aquí tenemos que considerar el concepto de Licitud de ese tratamiento.

En este apartado examinaremos varios puntos interesantes, pero recomendamos al lector profundizar en su conocimiento cuando tenga que realizar un sistema que "trate" datos personales.

El tratamiento será **lícito**, como principio general si existe consentimiento por parte del interesado: El interesado facilitó el consentimiento del tratamiento de sus datos para el fin o finalidades requeridos (art 6.1 a RGPD).

A partir de aquí surgen, por un lado, **excepciones a la exigencia de la solicitud del consentimiento**; por otro y de mucho interés, los tratamientos especialmente críticos. Destacamos:

- **Menores de edad.** El consentimiento al tratamiento de datos personales debe ser facilitado por los padres o tutores (hay que tener en cuenta que las minorías de edad son diferentes según estados miembros de la UE).
- **Categorías especiales (art. 9).** En este caso, se prohíbe de manera taxativa el tratamiento de datos personales de datos considerados especiales:
 - Los datos que revelen el **origen étnico o racial**.
 - Las **opiniones políticas**.
 - Las convicciones **religiosas**.
 - Las convicciones **filosóficas**.
 - La **afiliación sindical**.
 - Los tratamientos de **datos genéticos**.
 - Los **datos biométricos** dirigidos que identificar **unívocamente** a una persona.
 - Los datos relativos a la **salud** de las personas.
 - Los datos relativos a la **vida sexual** de las personas o a su **orientación sexual**.

En todos estos casos, puede mediar consentimiento explícito por parte del afectado o bien excepciones contempladas en la ley.

6.1.2.4. Derechos de interesado

El nuevo desarrollo normativo robustece los derechos de los ciudadanos respecto a la Directiva Europea 95/46/CE, dotándoles de más capacidad de control sobre sus datos personales y como es lógico trata también de responder a las necesidades de armonización del espacio europeo para facilitar el flujo de datos personales.

Derecho de información Art 13 y 14	1.Derecho a conocer la existencia de un tratamiento de datos personales o un fichero al que los datos personales serán incorporados y de la finalidad del mismo. Transparencia
Derecho de Acceso. Art.15	1.Derecho de acceso a sus datos personales, para conocer que datos han sido recabados y están siendo tratados
Derecho de Rectificación. Art.16	1.Poder rectificar los datos que no estén actualizados o no sean necesarios para el fin que persigue el tratamiento
Derecho de supresión (Derecho al Olvido). art.17	1.La capacidad de cancelar los datos , de manera que no sigan siendo tratados , 2.Y la obligación del R.T de notificar a terceros la supresión de los datos Art 19 (aplicable también a las limitaciones de tratamiento)
Derecho de limitación del tratamiento. Art 18	1.Derecho al requerir el tratamiento limitado de los datos temporalmente , por activación de reclamaciones o por aplicación del derecho de supresión con limitaciones por Ley
Derecho de Oposición. Art 21	1.Oponerse a un tratamiento, cuando no esté basado en el consentimiento del afectado por motivos legales
Derecho a la portabilidad de los Datos. Art.20	1.A que los datos sean transferidos de una organización a otra a instancia del interesado
Oposición a decisiones automatizadas, Art 22	1.Derecho a no ser objeto de decisiones que tengan un efecto jurídico sobre el interesado o le puedan afectar significativamente y que se basen en tratamientos automatizados de datos, lo que incluye la elaboración de perfiles.

Ilustración 5. Relación de derechos del interesado en la GDPR.

6.2 Protección frente a errores

La complejidad que supone analizar los problemas y errores que nos podemos encontrar en las soluciones de software en general, y en inteligencia artificial en particular, que ya están implantadas en nuestra empresa, universidad o incluso cliente nos llevan plantear una aproximación al desarrollo preventivo.

Aunque siempre se consideran los posibles problemas o retos que nos encontraremos al realizar el diseño de una aplicación, no se hacen aproximaciones en que este diseño esté orientado directamente a contemplar todos los requisitos de seguridad y privacidad que deberán 'resolver' en operación.

En este sentido han surgido conceptos, consolidados con métodos y técnicas, para evitar solucionar los problemas a posteriori y dedicar un esfuerzo no contemplado a la solución de errores. Esto es particularmente crítico en varias áreas entre las que destacan la seguridad y la privacidad, que pueden suponer no sólo desprestigio (riesgos) sino costes por sanciones, demandas e incluso secuestros de datos y chantajes.

A continuación nos acercaremos a estos puntos importantes que nos van a permitir crear soluciones robustas y seguras.

6.2.1. Seguridad por Diseño

El concepto **Seguridad por diseño (SbD o Secure by Design)**, es una premisa en la ingeniería de desarrollo que contempla que el diseño del producto, sus características y funciones son seguras de base.

Este enfoque de desarrollo está ligado a la privacidad garantizando tanto esta como la seguridad mediante estrategias, tácticas y patrones de seguridad alternativos. Durante el diseño se analizan y es al definir la mejor arquitectura cuando se aplican aquellos que cumplan los requerimientos y se utilizan como principios rectores para los desarrolladores. También se recomienda utilizar patrones de diseño estratégicos que tengan efectos beneficiosos sobre la seguridad, si bien es cierto que esos patrones de diseño no se diseñaron originalmente teniendo en cuenta la seguridad. Hablamos de procesos SecDevOps.

Todas estas tácticas y patrones de seguridad están centrados en requisitos fundamentales como son: autenticación, autorización, integridad de datos,

confidencialidad, privacidad, responsabilidad, no repudio, disponibilidad y seguridad en todo momento, garantizando la persistencia de esta.

En general, podemos conseguir un nivel de desarrollo seguro por diseño siguiendo pasos que contemplan:

1. Elegir la tecnología adecuada y hacer uso de la seguridad que incluye (y ya está testada).
2. Informar, concienciar y capacitar a los desarrolladores de las amenazas típicas y formas de solucionar.
3. Promover el reconocimiento de factores desencadenantes (situaciones reconocibles) en que deben aplicarse los principios de SbD (por ejemplo en [OWASP](#)).
4. Disponer el código fuente mantenible como requisito obligatorio, incluso haciendo uso de herramientas que midan su tratamiento.
5. Hacer uso de herramientas que permitan automatizar verificaciones.
6. Complementar las herramientas anteriores con especialistas que hagan de 'tester' y tutores de los desarrolladores.
7. Hacer uso de la Privacidad por Diseño y sus principios reguladores (ver apartado siguiente).
8. Hacer uso de marcos de mejora continua, como puede ser OWASP SAMM.

Un aspecto final que contemplar es el de crear un equipo de comprobación de vulnerabilidades en los sistemas heredados que no fueron diseñados bajo la SbD.

6.2.2. Privacidad por Diseño

La **privacidad por diseño (PbD o Privacy by Design)** es un concepto que desarrollado por Ann Cavoukian, Ph, Comisionada de Información y Privacidad Ontario, Canadá en los años 90, con el objeto de responder a los retos de los sistemas de datos en red y a gran escala.

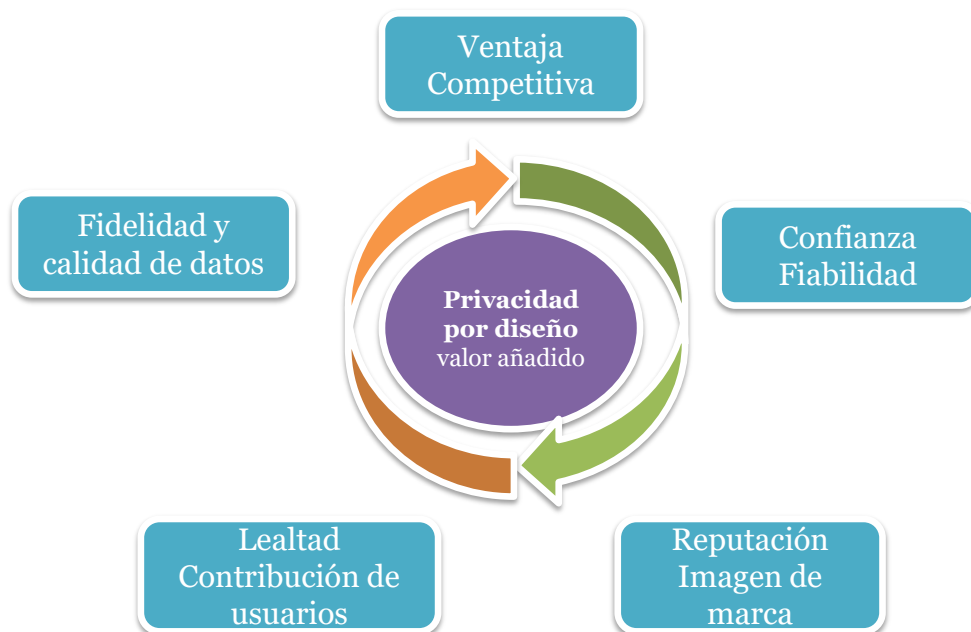


Ilustración 6. Valor añadido de la Privacidad por diseño

Nace como evolución al concepto de **tecnologías de mejora de la privacidad** y promueve garantizar la privacidad en todo el ciclo de vida de los datos no solo desde el desarrollo de marcos regulatorios, sino también integrándola en el centro de las actividades de las organizaciones y englobando:

- Sistemas de tecnologías de la información.
- Prácticas de negocio responsables.
- Diseño físico e infraestructura en red.

Y de este modo poder asegurar la privacidad y obtener control de las personas de su propia información, facilitando el principio de autodeterminación informativa de los afectados y ofreciendo además a las organizaciones una ventaja competitiva sostenible.

La **Privacidad por Diseño (PbD)** desarrolla siete principios que pueden ser aplicados a todo tipo de información personal y con especial atención a datos de significada sensibilidad como es la información médica y datos financieros.

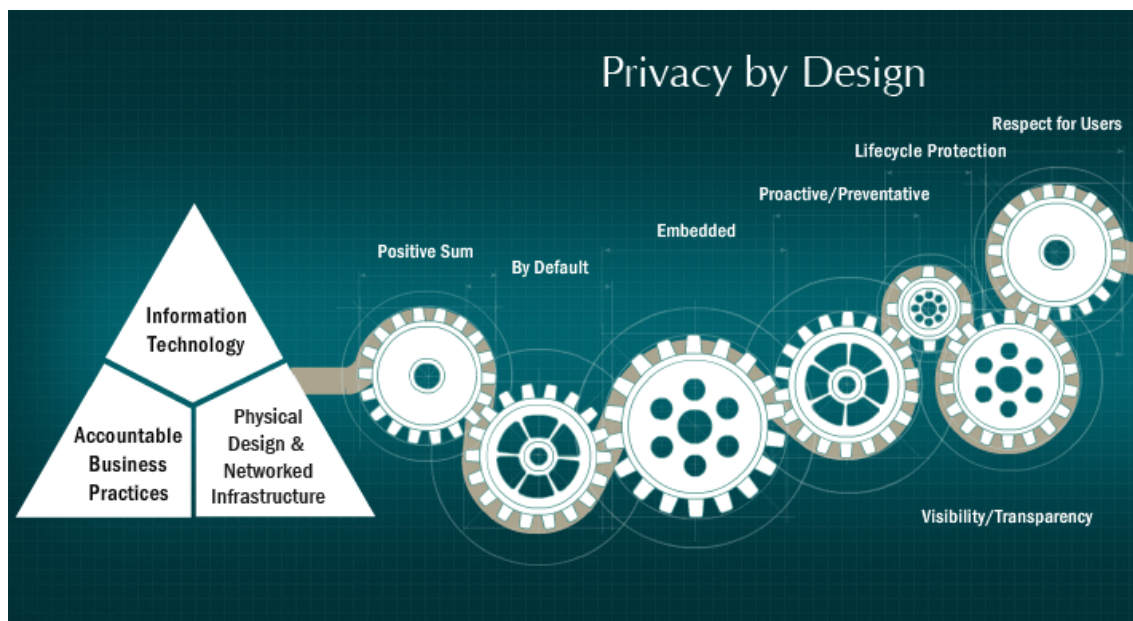


Ilustración 7. Principios de Privacidad por diseño o Privacy by design

Fuente: www.privacybydesign.ca

Estos **siete principios fundamentales**, son:

- » **Proactivo, no reactivo; preventivo no correctivo.** El enfoque basado en medidas proactivas, en vez de reactivas. Anticipar y prevenir eventos de invasión de la privacidad antes de que estos ocurran.
- » **Privacidad como la configuración predeterminada (privacidad por defecto).** Asegurándose de que los datos personales estén protegidos automáticamente y por defecto en cualquier sistema de TI o en cualquier práctica de negocios, actuando como una configuración predeterminada de alta privacidad que requeriría la acción de la persona o el usuario para reducir esa configuración de garantía y facilitar acceso a su información. Dentro de esta configuración determinada y como buenas prácticas se incluiría:
 - **Finalidad:** información recolectada debe ser una finalidad concreta.
 - **Información:** el usuario debe ser informado de la finalidad de la recolección.
 - Limitar los datos a la finalidad especificada.
 - Anonimizar los datos, limitar el uso de los datos, su retención, divulgación a la finalidad con la que fueron recabados y a las regulaciones legales.

- » **Privacidad incrustada en el diseño.** La Privacidad por Diseño se incrusta en el diseño y la arquitectura de los sistemas de información y en las prácticas de negocios. Se convierte en un componente esencial de la funcionalidad central que está siendo entregada. La privacidad es parte integral del sistema, sin disminuir su funcionalidad.
- » **Funcionalidad total «todos ganan», no «si alguien gana, otro pierde».** Privacidad por Diseño busca acomodar todos los intereses y objetivos legítimos de una forma **ganar-ganar** y evita las falsas dualidades, tales como privacidad versus seguridad, partiendo de la idea de que sí es posible tener ambas al mismo tiempo.
- » **Seguridad extremo a extremo. Protección de ciclo de vida completo.** Protección de dato en todo el ciclo de vida, desde la recolección del dato pasando por su almacenamiento y retención y la fase final su destrucción adecuada. Para ello se recurriría a la aplicación de medidas de seguridad eficaces.
- » **Visibilidad y transparencia. Mantenerlo abierto.** Que las partes involucradas, negocio y tecnologías operen de conformidad a objetivos claros y declarados de forma transparente y bajo el principio de que todas las operaciones van a ser realizadas de conformidad con las premisas y objetivos fijados y van a estar sujetos a esquemas de verificación independientes.
- » **Respecto por la Privacidad de los Usuarios. Mantener un enfoque centrado en el usuario.** Por encima de todo, requiere que los arquitectos y operadores prioricen el interés de las personas ofreciendo servicios robustos de privacidad por defecto, información adecuada y opciones amigables para el usuario facilitándonos el control sobre sus datos.

A fondo

NO DEJES DE LEER....

Estudio práctico sobre la protección de datos de carácter personal

Almuzara, C. (coord.). (2007). Estudio práctico sobre la protección de datos de carácter personal. Valladolid: Editorial Lex Nova.



Un completo análisis de las implicaciones jurídicas derivadas de la normativa de protección de datos personales, que incorpora un gran número de ejemplos prácticos, recomendaciones y jurisprudencia; muy útil en la práctica.

Accede a una parte del libro desde el aula virtual o a través de la siguiente dirección web:

<http://books.google.es/books?id=jFjsUqwMQkC&printsec=frontcover>

Secure By Design

Dan Bergh Johnsson; Daniel Deogun; Daniel Sawano (2019): Editorial Manning.



Este libro enseña a desarrolladores como utilizar el diseño para orientar a la seguridad el desarrollo de software, e incluye patrones, mejores prácticas e ideas para aplicar al desarrollo.

Accede a una parte del libro desde el aula virtual o a través de la siguiente dirección web:

[Google libros](#)

Texto del Reglamento General de Protección de Datos

REGLAMENTO (UE) 2016/679 del Parlamento Europeo y del Consejo de 27 de abril de 2016 relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos.

Accede al Reglamento a través del aula virtual o desde la siguiente dirección web:

<https://www.aepd.es/es/documento/reglamento-ue-2016-679-consolidado.pdf>

WEBGRAFÍA

Agencia Española de Protección de Datos

Encontrarás preguntas frecuentes, documentación de soporte, e información sobre procedimientos sancionadores.



Accede a la página desde el aula virtual o a través de la siguiente dirección web:

www.aepd.es

Comisión Europea

En esta página encontrarás información sobre la Comisión Europea para el nuevo Reglamento de Protección de Datos.



Accede a la página desde el aula virtual o a través de la siguiente dirección web:

ec.europa.eu/justice/data-protection/index_en.htm

Parlamento Europeo

Información sobre el nuevo Reglamento de Protección de Datos y su proceso legislativo.



Accede a la página desde el aula virtual o a través de la siguiente dirección web:

www.europarl.europa.eu/sides/getDoc.do?pubRef=-//EP//TEXT+TA+P7-TA-2014-0212+0+DOC+XML+V0//ES

Derecho TIC

Red de especialistas en Derecho de las TIC.

Derecho TICs

Accede a la página desde el aula virtual o a través de la siguiente dirección web:

www.derechotics.com/

LECCIONES MAGISTRALES

Inteligencia artificial ética y auditable: buenas y malas prácticas

Ponencia sobre innovación, protección de datos y transformación digital del ciclo 'Innovación y Protección de Datos. Mujer y Ciencia' a cargo Gemma Galdón Clavell, analista de políticas públicas especializada en el impacto social, legal y ético de las tecnologías intensivas en datos personales y en la auditoría de algoritmos.

Galdón es fundadora y directora de Eticas Research and Consulting y fue finalista del Premio de la UE a las mujeres innovadoras 2017. Ha sido

investigadora principal en más de 10 grandes proyectos de I+D. Es experta científica y en ética para la Dirección General de Investigación e Innovación de la Comisión Europea y forma parte del consejo asesor de Privacy International y Data & Ethics.

Esta es la tercera entrega del ciclo de cinco debates (webinarios) sobre 'Innovación y Protección de Datos. Mujer y Ciencia' organizados por la Agencia Española de Protección de Datos (AEPD)..

Accede a la lección magistral a través de Youtube en:

<https://www.youtube.com/watch?v=zDDnT41hDU0>